# International Cybersecurity and Digital Forensics Academy (ICDFA)

**Course Code:** GRC103 – Risk Assessment and Management Techniques

## Practical Laboratory

### Social Engineering & Phishing Campaign Simulation for GRC Professionals

*Scenario: Single-subject authorised phishing simulation, self-hosted GoPhish lab environment*

Role in Scenario: GRC Analyst / Security Testing Lead

**Student Name:** Mercy Ajayi

**Registration Number:** C11/26/CGRCE/17219

**Date of Submission:** November 7, 2026

# TABLE OF CONTENT

**1. Laboratory Setup and Method.....1**
1.1 Local Environment..... 1
1.2 Campaign Components..... 1
**2. Campaign Evidence.....2**
2.1 Sending Profile configuration (credentials concealed).....2
2.2 Sending Profiles list..... 3
2.3 Phishing email received in the Mailtrap sandbox.....3
2.4 Campaign summary — recent campaigns view..... 4
2.5 Campaign results — funnel counters.....4
2.6 Campaign results — per-recipient detail.....5
2.7 Campaign results page and timeline..... 5
**3. Phishing Risk Assessment Table.....6**
**4. Executive Summary and Recommendations.....7**
4.1 Scope and method.....7
4.2 Key findings..... 7
4.3 Business implications..... 7
4.4 Recommended actions (prioritised)..... 8
**5. Limitations.....9**

# 1. Laboratory Setup and Method

This laboratory was carried out as a controlled, self-contained simulation. Only the author was used as the test subject, and all activities were kept within the virtual environment. No real individuals or external domains were targeted.

## 1.1 Local Environment

- **Host machine:** Windows 10 running Oracle VirtualBox.
- **Guest machine:** Kali Linux VM, used to run GoPhish and carry out the simulation.
- **Phishing framework:** GoPhish v0.12.1, running locally on Kali. The admin interface was accessed through `https://127.0.0.1:3333`, while the phishing server ran at `http://127.0.0.1`.
- **Sending relay:** Mailtrap Email Testing sandbox using SMTP, which kept the test emails within the controlled environment rather than sending them to a real mail server.
- **Target:** One authorised test subject, the author, who was the only member of the campaign's target group.

## 1.2 Campaign Components

The simulation was set up with the following components:

- **Sending Profile:** "Mailtrap Test", configured to use Mailtrap's SMTP sandbox relay at `sandbox.smtp.mailtrap.io:2525`.
- **Landing Page:** "Fake VPN Portal", a simple mock corporate VPN login page created for the lab. It was not copied from any real organisation. The page was configured to record submitted data and then redirect the user to a training page.
- **Email Template:** "VPN Password Reset Required", designed around an urgency-based message stating, "Action Required: Your VPN Password Expires in 24 Hours". GoPhish variables such as `{{.FirstName}}` and `{{.URL}}` were used to personalise the message and insert the campaign link.
- **Target Group:** "Lab Test Group", containing only the author's test account.

The campaign, named **"Q3 GRC Phishing Simulation,"** was then launched against the test account. GoPhish recorded the different stages of the simulation, including email delivery, opening the message, clicking the link, and submitting credentials.

# 2. Campaign Evidence

The screenshots below are taken directly from the GoPhish admin interface and the Mailtrap sandbox inbox. SMTP credentials are concealed: the password field is masked by GoPhish's own input masking, and the username field has been manually redacted before inclusion in this report.

## 2.1 Sending Profile configuration (credentials concealed)

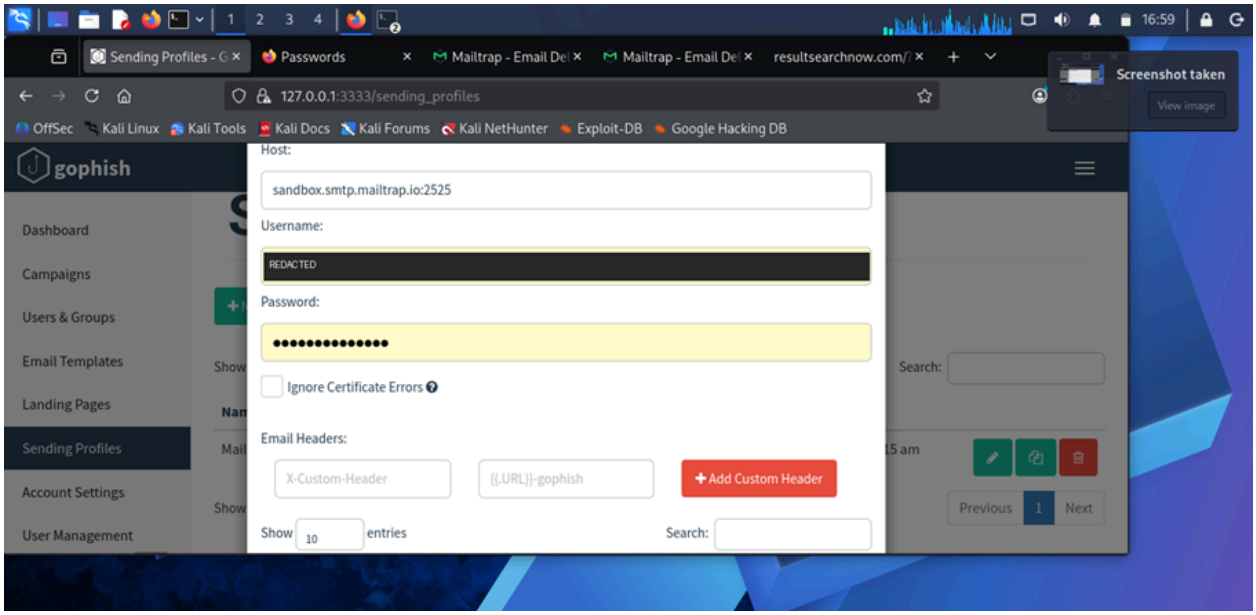



*Figure 1. Mailtrap SMTP sending profile, with username redacted and password masked.*

## 2.2 Sending Profiles list

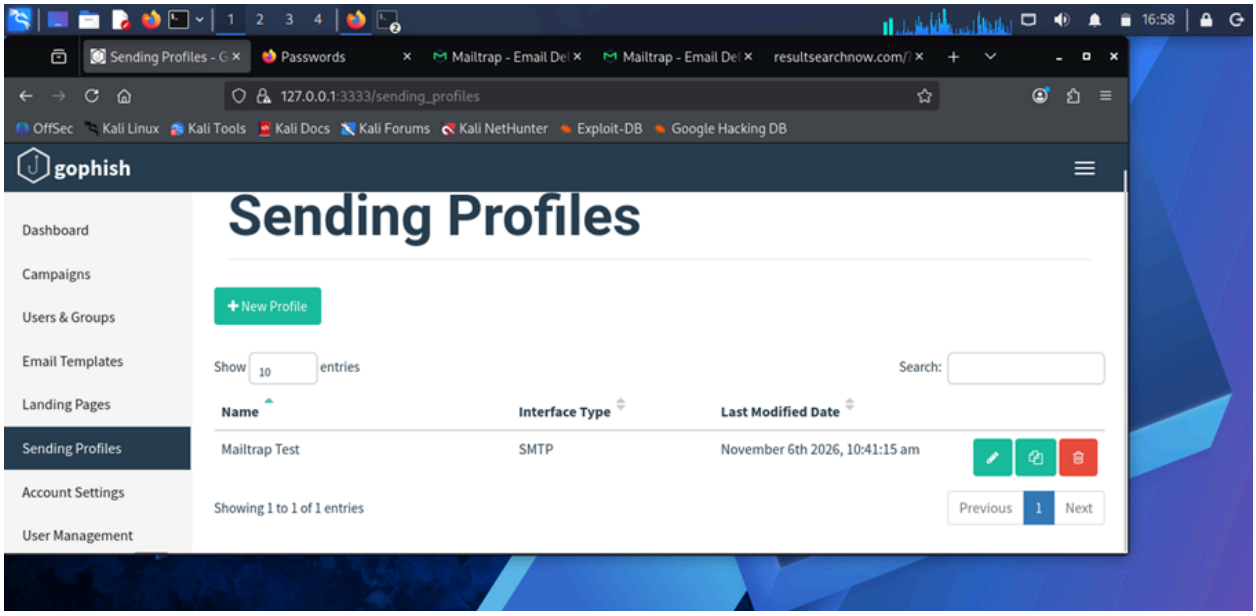



*Figure 2. Saved sending profile in GoPhish.*

## 2.3 Phishing email received in the Mailtrap sandbox

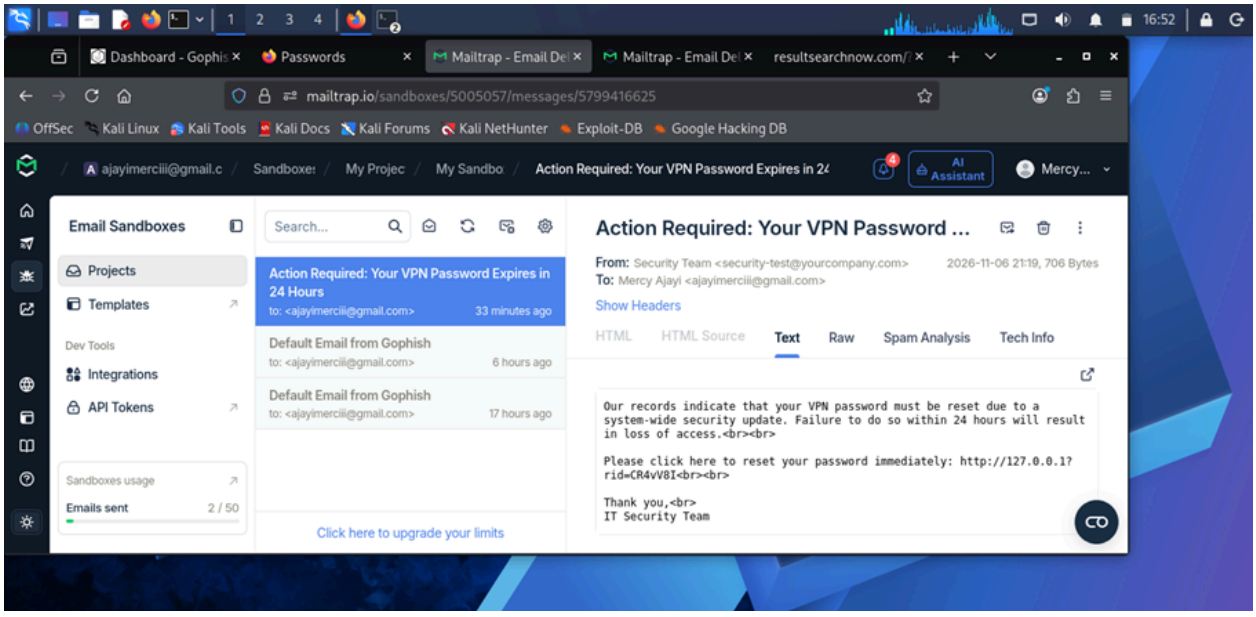



*Figure 3. The "VPN Password Reset Required" lure as it arrived in the sandbox inbox.*

## 2.4 Campaign summary — recent campaigns view

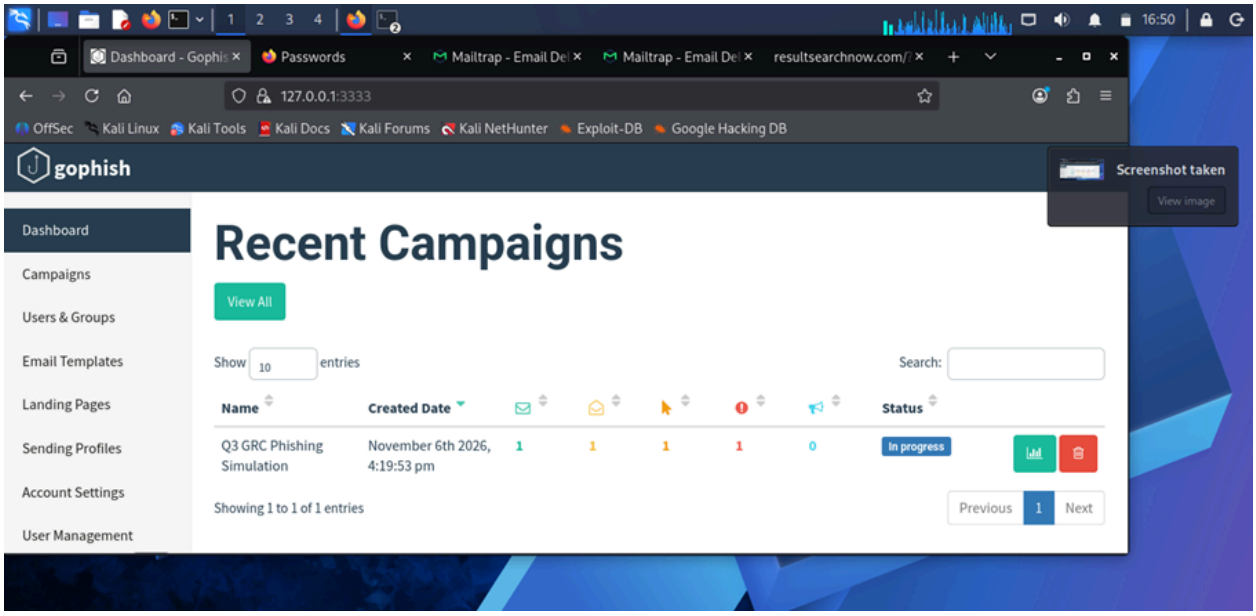



*Figure 4. GoPhish dashboard showing the completed campaign: 1 sent, 1 opened, 1 clicked, 1 submitted, 0 errors.*

## 2.5 Campaign results — funnel counters

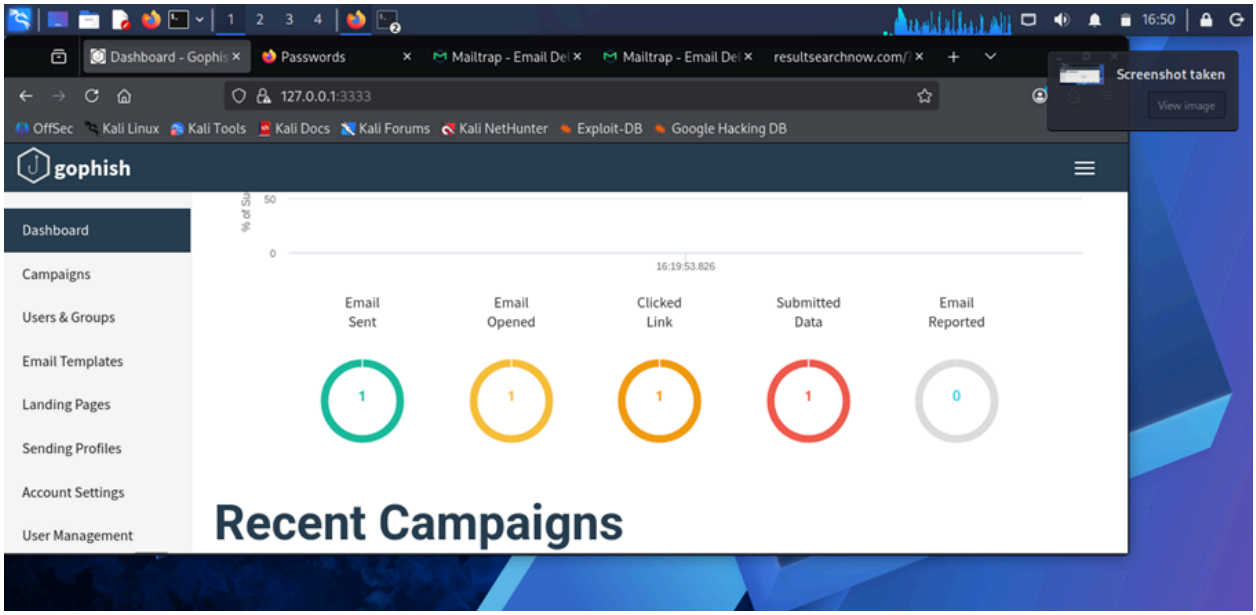



*Figure 5. Full-funnel result: Email Sent, Email Opened, Clicked Link and Submitted Data each at 1 of 1.*

## 2.6 Campaign results — per-recipient detail

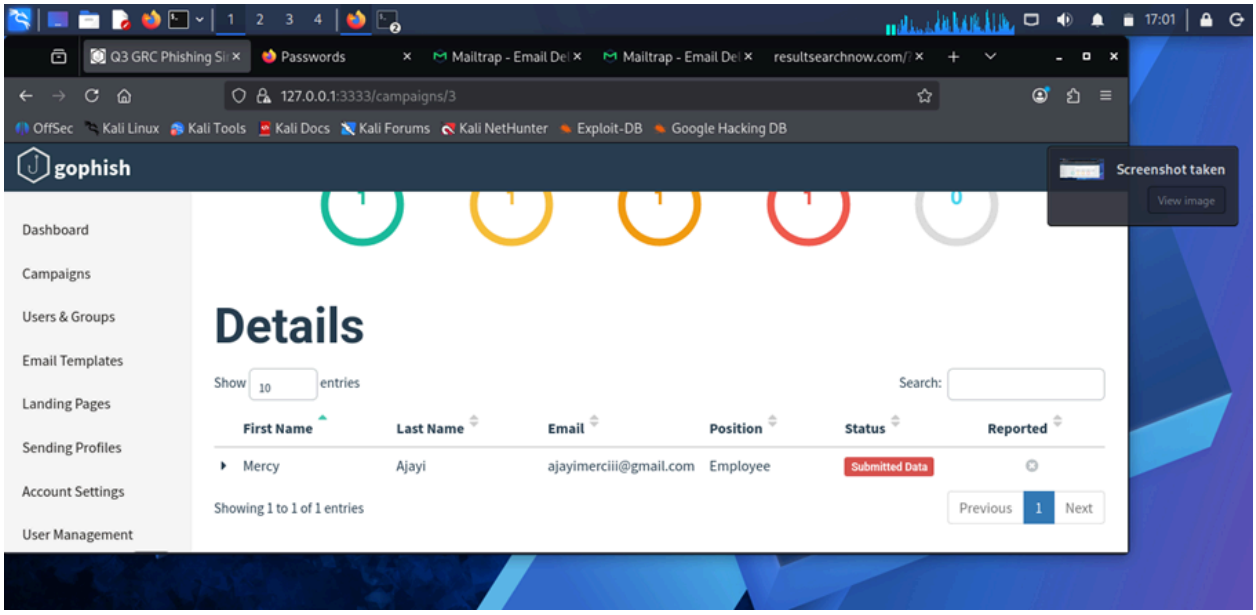



*Figure 6. Per-recipient detail table showing final status: Submitted Data.*

## 2.7 Campaign results page and timeline

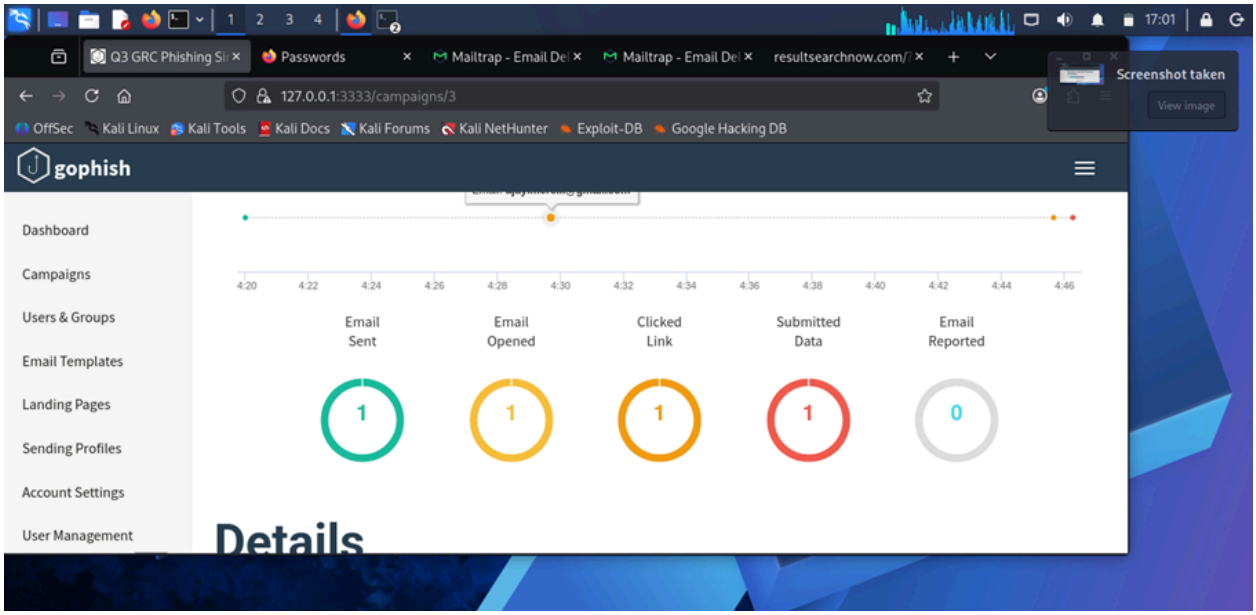



*Figure 7. Results page for "Q3 GRC Phishing Simulation," showing the funnel counters and campaign timeline.*

## 3. Phishing Risk Assessment Table

The simulation involved only one authorised test subject, so the sample size was 1. This means that all observed rates are either 0% or 100%. These results are reported based on the actual outcome of the test and are not presented as a measure of organisation-wide phishing susceptibility. The limitation of using a single subject and its effect on the interpretation of the results are discussed in Section 5.

| Metric | Event Count | Denominator | Rate | Risk Interpretation | Recommended Control |
|---|---|---|---|---|---|
| Emails Sent | 1 | 1 | 100% | The email was successfully delivered without a bounce or filtering rejection. This shows that the message reached the test inbox. | Review and strengthen email security controls, including SPF, DKIM, DMARC and anti-phishing filtering. |
| Emails Opened | 1 | 1 | 100% | The recipient opened the email, showing that the urgency used in the message was effective in getting their attention. | Provide security awareness training on recognising urgency-based social engineering and phishing messages. |
| Links Clicked | 1 | 1 | 100% | The recipient clicked the link without checking the sender or destination URL first. This shows a gap in basic link verification. | Train users to verify senders and links before clicking, supported by URL scanning and email security controls. |
| Credentials Submitted | 1 | 1 | 100% | The recipient entered login details on the mock VPN page without identifying that it was a phishing page. In a real attack, this could result in credential theft. | Enforce MFA on VPN and other remote-access systems so that a stolen password alone is not enough to gain access. |

# 4. Executive Summary and Recommendations

## 4.1 Scope and method

A controlled social-engineering simulation was carried out using GoPhish in an isolated Kali Linux virtual machine. Email delivery was handled through a Mailtrap testing sandbox, so the simulation did not involve any production mail systems or external recipients.

The test simulated a credential-phishing attack using an urgent VPN password-reset message. It was carried out against one authorised test subject, the author. No real individuals, production systems, or third-party domains were involved.

## 4.2 Key findings

The simulation showed the following:

- The phishing email was successfully delivered (1 of 1).
- The email was opened by the recipient (1 of 1).
- The link was clicked without first checking the sender or destination URL (1 of 1).
- Login credentials were entered on the mock VPN landing page (1 of 1).

The test therefore completed the full simulated phishing chain, from delivery to credential submission. No technical control or user action stopped the attack at any stage.

## 4.3 Business implications

Since the test subject completed every stage, the simulation shows the potential impact of a successful credential-phishing attack against a user.

In a real organisation, compromised VPN credentials could potentially lead to:

- Unauthorised access to internal systems.
- Further movement within the network if the compromised account has access to other systems or sensitive resources.
- Exposure of personal or customer information, which could create regulatory and reputational issues.
- Follow-up attacks such as business email compromise or ransomware.

The simulation did not test MFA as a blocking control. Therefore, the results also highlight why relying on passwords alone for remote access can create additional risk after credentials have been exposed.

### 4.4 Recommended actions (prioritised)

The following controls are recommended based on the results:

1. **Enforce MFA on VPN and other remote-access systems.** This should be the highest priority because MFA can provide an additional layer of protection even when a password has been successfully phished.
2. **Strengthen email filtering.** Configure email security controls to identify suspicious messages, particularly those combining urgency with links that request login or other sensitive information.
3. **Run regular phishing simulations.** Future tests should be carried out periodically with a representative group of staff. This would provide a more useful picture of the organisation's actual susceptibility than the single-subject test.
4. **Provide security awareness training.** Training should focus on checking links and sender details, as well as recognising common social-engineering techniques such as urgency and pressure to act quickly.
5. **Create an easy phishing-reporting process.** Staff should have a clear way to report suspicious emails so that the security team can investigate and respond quickly.

# 5. Limitations

- **Single test subject:** The sample size was 1, so the results in Section 3 are based on one person's actions. The 0% and 100% rates should therefore not be treated as an organisation-wide susceptibility rate.
- **No repeated trials or control group:** Only one test was conducted, so the results cannot show whether the behaviour would remain the same with different users or under different conditions.
- **Generic landing page:** The mock VPN page was created specifically for the lab and was not a copy of a real organisation's portal. A more convincing or organisation-specific phishing page could produce different results.
- **Controls were not tested directly:** MFA, email filtering and other recommended controls were discussed based on their expected effect, but they were not deployed and tested as part of this simulation.
- **Single phishing scenario:** The test focused only on an urgency-based VPN password-reset lure. Other phishing approaches, such as financial scams or executive impersonation, were not tested, so the results cannot be applied to those scenarios.